Практическое задание

Анализ вредоносной программы и выбор методов защиты

Вариант А: червь WannaCry (2017)

ФИО: _____ Группа: _____

Шаг 1. Описание вредоносной программы

Тип по механизму распространения	Червь: самостоятельная программа, которая распространяется по сетям без участия пользователя, сама находит уязвимые системы и заражает их.
Тип по функциональности	Ни шпионская программа, ни adware, ни руткит. Основная функция — деструктивная: блокировка доступа к данным путём шифрования.
Тип по способу монетизации	Рансомер (крипто-рансомер): шифрует данные и требует выкуп за расшифровку.
Полезная нагрузка	Шифрование файлов на заражённом компьютере и вывод требования выкупа за расшифровку.
Способы распространения	Через локальные и глобальные сети: червь использует уязвимость в протоколе SMB операционной системы Windows и заражает новые компьютеры автоматически, без действий пользователя.

WannaCry состоит из всех трёх частей, описанных в лекции: механизма распространения (червь, уязвимость SMB), полезной нагрузки (шифрование) и средств для вымогательства (требование выкупа). Масштаб: заражено более 200 тысяч компьютеров в 150 странах.

Шаг 2. Оценка рисков

Объекты уязвимости	Компьютеры на Windows с незакрытой уязвимостью в SMB (не установлены патчи безопасности); открытый сетевой доступ к SMB; пользовательские и корпоративные данные, ставшие целью шифрования; локальные сети организаций, где червь легко переходит с узла на узел.
Угрозы надёжности	Потеря доступности данных и сервисов (файлы зашифрованы, системы не работают); остановка бизнес-процессов организаций; возможная безвозвратная потеря данных, если нет резервных копий; массовый характер ущерба из-за быстрого распространения.
Вероятность заражения	Высокая для систем без обновлений и с доступным SMB в сети (червь заражает их сам, без действий пользователя). Низкая для полностью обновлённых систем, где уязвимость закрыта.
Тяжесть последствий	Высокая / критическая: данные недоступны, работа организации может остановиться, а для критической инфраструктуры (например, медицинской) последствия могут затрагивать людей.

Шаг 3. Методы обнаружения

Метод	Оценка	Обоснование
Сигнатурный	Высокая для уже известной версии, низкая для новой	Когда образец червя известен, его хеш, последовательности байтов и характерный сетевой трафик попадают в базу, и обнаружение быстрое и точное, почти без ложных срабатываний. Но в первые часы эпидемии сигнатур ещё нет (zero-day), а изменённые варианты (обфускация, полиморфизм) могут обойти сигнатуру.
Эвристический	Средняя / хорошая	Статический анализ находит подозрительные строки, функции и импорты в файле, а динамический анализ в песочнице показывает шифрование файлов и сетевое сканирование. Метод позволяет поймать новый вариант без готовой сигнатуры, но даёт больше ложных срабатываний, нагружает систему и требует тонкой настройки.
Поведенческий	Наиболее высокая	Поведение WannaCry типично для рансомера и червя: массовое шифрование файлов, множественные сетевые подключения к другим узлам по SMB, попытки заразить соседние компьютеры. Метод не зависит от сигнатуры и ловит неизвестные варианты. Минусы: нагрузка от мониторинга в реальном времени и то, что обнаружение происходит уже во время действий программы.

Вывод по шагу: лучше всего работает сочетание: сигнатуры для быстрого отсечения известных образцов и поведенческий анализ для новых вариантов. Дополнительно сетевые системы обнаружения вторжений (IDS) помогают заметить подозрительную SMB-активность в сети.

Шаг 4. Меры защиты

Профилактические меры

- Регулярное обновление ПО: установка патчей безопасности Windows, закрывающих уязвимость SMB, которую использует червь.
- Использование надёжного антивирусного ПО с актуальными базами и включёнными поведенческими модулями.
- Ограничение прав пользователей: работа под учётными записями с ограниченными правами снижает ущерб.
- Обучение пользователей основам безопасности (хотя червь распространяется без участия пользователя, общая осведомлённость снижает риски от других угроз).

Технические меры

- Межсетевые экраны: блокировка входящего и внутреннего трафика SMB там, где он не нужен.
- Системы обнаружения вторжений (IDS): мониторинг подозрительной сетевой активности и попыток эксплуатации SMB.
- Резервное копирование: регулярные бэкапы (с копиями, недоступными из заражённой сети) позволяют восстановить данные без выплаты выкупа.
- Шифрование данных для защиты конфиденциальной информации.

Организационные меры

- Политика безопасности: правила своевременного обновления систем и работы с информацией.
- План реагирования на инциденты: кто что делает, как оповещать, как изолировать заражённые узлы и восстанавливать данные.
- Регулярный аудит безопасности: поиск необновлённых систем и открытых сервисов.
- Сотрудничество с CERT для получения информации о новых угрозах и помощи при инцидентах.

Шаг 5. Наиболее эффективная мера защиты

Наиболее эффективная мера — **своевременное обновление ПО (установка патчей безопасности)**. WannaCry — это червь, который распространяется только через конкретную уязвимость в SMB. Если уязвимость закрыта, червь не может проникнуть в систему, то есть пропадает сам механизм распространения, а значит и полезная нагрузка (шифрование) не запускается. Это предотвращает заражение, а не борется с его последствиями.

Антивирус и обнаружение помогают лишь частично (сигнатур может ещё не быть, а поведенческий анализ срабатывает уже в ходе атаки), поэтому патчи — это основа защиты. Вторым по важности рубежом считаю **резервное копирование**: если заражение всё-таки произошло, бэкапы позволяют восстановить данные и не платить выкуп.